

信息安全测评与 风险评估

等保2.0标准体系框架学习

授课教师：张玉



Part. 01

什么是信息安全测评

从案例引入到核心概念解析



- 案例：棱镜计划（PRISM）

事件概述

2013年，美国情报外包公司前雇员爱德华·斯诺登曝光了美国国家安全局（NSA）的“棱镜”计划。该计划自2007年起，通过接入九大互联网公司的服务器，对全球范围内的电子邮件、即时消息、视频、照片、存储数据进行秘密监控。



影响范围

- **监控对象：**美国公民及全球各国政要、企业、民众
- **涉及企业：**微软、雅虎、谷歌、Facebook、PalTalk、YouTube、Skype、AOL、苹果
- **数据量：**每天收集的通信数据量高达**数十亿条**



聊一聊

这一事件给你的感受是什么？

- 案例：WannaCry勒索病毒（2017）

事件概述

2017年5月，勒索病毒“WannaCry”在全球爆发，感染150多个国家超20万台计算机。利用Windows漏洞（MS17-010）传播，加密文件并索要赎金。



⚠ 典型受害机构

- 英国**NHS**：医院瘫痪，手术取消
- 俄罗斯：内政部、铁路等遭攻击
- 中国：多所高校、加油站等受影响
- 美国：联邦快递等企业受影响



聊一聊

这个事件给你的感受又是什么？

- 案例启示与课程导入

| 讨论问题

- 棱镜门和WannaCry勒索病毒事件有什么共同特点？
- 该如何进行防范？

总结

这两个案例都揭示了信息系统安全防护不足可能导致的严重后果。

信息安全测评：发现安全隐患、验证安全能力、保障系统合规

- 什么是信息安全测评？

🪶 形象比喻

信息安全测评就像是给信息系统做一次全面的“健康体检”。

🔧 核心定义

依据国家信息安全标准规范，对信息系统的安全性进行检测、评估和验证的过程，发现系统中存在的安全隐患和薄弱环节，提出改进措施，确保系统达到预期的安全保护能力。

测评的四个目的

1 发现问题

2 验证能力

3 指导整改

4 规避风险

为系统安全整改提供依据

帮助组织识别并规避安全风险

测评准备



方案编制



现场测评



报告编制

所有系统都用一样的体检标准吗？

NO

网络安全等级保护制度

网络安全等级保护制度

等级保护制度是我国网络安全领域的基石，通过“分等级保护、分等级监管”的原则，为不同重要程度的信息系统构建精准的安全防护体系，避免“一刀切”带来的资源浪费或防护不足。



01 核心痛点：测评标准不可一刀切

普通办公网站与政务、医疗等核心系统重要性迥异。若采用统一标准，轻则造成资源浪费，重则导致关键系统防护强度不足，无法应对针对性攻击。



02 制度核心：闭环式分级管理

建立“定级→备案→建设整改→等级测评→监督检查”的闭环机制。针对不同等级的系统实施差异化的安全建设要求，确保防护措施与系统重要程度相匹配。



03 法律基石：网安法明确规定

《网络安全法》第二十一条将其确立为国家制度。网络运营者必须履行安全保护义务，保障网络免受干扰、破坏，防止数据泄露、窃取或篡改，违者将承担法律责任。

Part. 02

从等保1.0到等保2.0

等保发展历程与2.0核心标准



- 等保的发展历程

等保1.0时代（1994-2016）

1994年

首次提出“等级保护”概念

2007年

等保1.0正式实施
GB/T 17859-1999

等保2.0时代（2017-至今）

2017年6月

网络安全法施行
上升为法律要求

2019年5月

等保2.0核心标准
正式发布

2019年12月

等保2.0标准
正式实施

关键认知

等保2.0不是简单的版本升级，而是从“部门规章”上升为“**法律要求**”，从“信息系统”扩展为“**网络和信息**系统”的全面变革。

- 等保1.0与等保2.0的五大区别

对比维度	等保1.0	等保2.0
保护对象	信息系统	网络和信息系统（含云/移/物/工/大数据）
安全要求	技术+管理（10个安全控制类）	安全通用要求+安全扩展要求（五大类扩展）
标准体系	单一标准	1+N标准体系
法律依据	部门规章	《网络安全法》法律要求
安全理念	被动防御	主动防御、动态防御

Part. 03

等保2.0标准体系框架

1+N体系与安全等级划分



- 等保2.0标准体系框架

■ 核心标准

GB/T 22239-2019 《信息安全技术 网络安全等级保护基本要求》

——“根本大法”，一切测评工作的依据

■ 配套标准（N）

- GB/T 28448-2019 《信息安全技术 网络安全等级保护测评要求》

- GB/T 28449-2018 《信息安全技术 网络安全等级保护测评过程指南》

- GB/T 25070-2019 《信息安全技术 网络安全等级保护安全设计技术要求》

- GB/T 36958-2018 《信息安全技术 网络安全等级保护安全管理中心技术要求》

■ 五大扩展要求

- 云计算安全扩展要求
- 移动互联安全扩展要求
- 物联网安全扩展要求
- 工业控制系统安全扩展要求
- 大数据安全扩展要求

- 等保2.0的安全等级划分

第五级（访问验证保护级）

国防/军事极端重要系统

第四级（结构化保护级）

国家重要领域核心系统

第三级（安全标记保护级）

地市级政务/金融机构

最常见，每年至少测评一次

第二级（系统审计保护级）

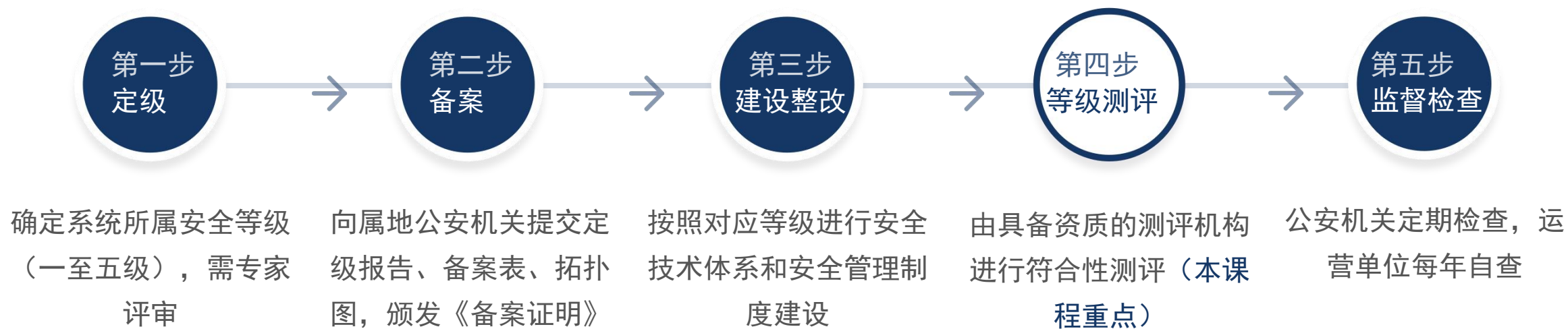
县级政务/高校/一般企业

每两年至少测评一次

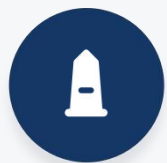
第一级（用户自主保护级）

乡镇级/中小企业

- 等保工作“五步走”流程



- 等保测评的四个阶段



第一阶段测评准备

项目启动、信息收集、
工具准备、签署保密
协议



第二阶段方案编制

确定范围、选取对象、
确定指标、编制方案、
评审



第三阶段现场测评

技术测评（物理/网
络/主机/应用/数据）
+ 管理测评



第四阶段报告编制

单项合规性判定、整
体结论、整改建议、
审核、交付测评报告

i

教学提示：这四个阶段就是本课程项目1至项目6的编排顺序。

- 本部分知识回顾快速问答

Q: 什么是等保2.0?

A: 等保2.0是国家网络安全等级保护制度的第二代标准体系, 以《网络安全法》为法律依据, 以GB/T 22239-2019为核心标准。

Q: 等保2.0有哪五个安全等级?

A: 第一级至第五级。第三级最常见。

Q: 等保工作“五步走”是哪五步?

A: 定级 → 备案 → 建设整改 → 等级测评 → 监督检查。

Q: 等保测评“四阶段”是哪四阶段?

A: 测评准备 → 方案编制 → 现场测评 → 报告编制。